



TTP Analysis: Deconstructing a Coordinated SSH Botnet Ecosystem

MAY 2026 | R33 | v1.0



Table of Contents

Table of Contents	2
1. Executive Summary	3
2. The SSH Ecosystem: A Division of Labor.....	4
2.1 The "Checker" Nodes (The Verifiers)	4
2.2 Deconstructing the "Seychelles" Proxy: A Compromised C2 Node	5
2.3 The "Operator" Nodes (The Payload Delivery)	6
2.4 The Outlier: Credential Stuffing.....	7
2.5 Attack Flow Diagram	7
3. Micro-Analysis: The <i>mdrfckr</i> Payload	8
Phase 1: Defensive Evasion	8
Phase 2: Resource Profiling (The "Why").....	9
Phase 3: Hostile Takeover	9
Phase 4: Persistence.....	10
4. The Parallel Universe: Dionaea Service Scanning	10
The Database Frenzy:.....	10
The Echoes of EternalBlue:	11
Targeted Database Probing:	11
Legitimate Noise:.....	11
5. Conclusion & Intelligence Takeaways.....	12
6. Indicators of Compromise (IOCs)	13
6.1 Network IOCs (Malicious Infrastructure)	13
6.2 Cryptographic IOCs.....	15
6.3 Observed Authentication Material (Contextual).....	15
6.4 Exclusions / Whitelisted IOCs (Do Not Block)	16



1. Executive Summary

Date of Observation:	May 11, 2026 (17:13 UTC – 20:57 UTC)
Infrastructure:	T-Pot Honeypot (Xserver) deployed on the Cloud (X.X.X.X)
Focus:	Exploratory analysis of attacker TTPs, botnet division of labor, and parallel scanning ecosystems.

When a new IP address is provisioned on a major cloud provider, it does not sit in silence. When I deployed my cloud instance, within minutes it was absorbed into the gravitational pull of internet background radiation. Over a four-hour window, the honeypot recorded over 5,000 interactions across 10 distinct emulated services. By moving past the bulk of the record and looking deeply at the session data, a fascinating picture of the cybercrime ecosystem emerges. What I saw was not a single "attack," but rather overlapping, automated economies operating in parallel: a highly structured SSH brute-force campaign exhibiting a strict division of labor, concurrent database-ransom scanning, and the lingering echoes of historic network worms.



Figure 1 – A snapshot of the numbers of attacks during the four-hours window



2. The SSH Ecosystem: A Division of Labor

From the 5,000+ interactions the T-Pot recorded in four hours, the vast majority were generic "noise"—failed login attempts that provide little to no intelligence value. To cut through this noise, T-Pot utilizes **Cowrie**, a medium-interaction SSH and Telnet honeypot.

Unlike a standard firewall log that merely records a failed authentication, Cowrie actually accepts the credentials provided by the attacker. It traps them in an emulated Linux file system. This is a critical distinction for threat intelligence: while the attacker *believes* they have successfully compromised a server and are executing commands, we are safely recording their every post-exploitation move.

During this observation window, Cowrie recorded 16 of these "successful" sessions. However, a deep analysis of the post-login telemetry reveals a critical insight: not all successful logins are created equal. By examining what the attackers did—or didn't do—after gaining access, the data clearly delineates three distinct classes of actors operating within this single campaign.

2.1 The "Checker" Nodes (The Verifiers)

Most of the successful logins originated from IPs in Indonesia ([115.85.80.12](#)), Singapore ([43.160.200.19](#)), and the Seychelles ([156.238.224.50](#)). These nodes successfully authenticated using credentials like [tests:tests](#), [stuser:stuser](#), and [test:haslo](#).

Yet, when we cross-reference these IPs in the command input logs via their unique Cowrie Session IDs (E.G., [E0D990A093D9](#)), they are entirely absent. They logged in, realized they had a shell, and immediately disconnected without typing a single command.

Analytical Conclusion: These machines are compromised hosts acting as "Checker" nodes. Their sole purpose in the botnet economy is to verify if stolen credential lists are valid. Once they verify a credential works, they report that success back to a Command & Control (C2) server, which then dispatches a different class of node to do the actual work.



2.2 Deconstructing the "Seychelles" Proxy: A Compromised C2 Node

One of the most deceptive actors in this dataset was ([156.238.224.50](#)), which initially stood out for successfully authenticating using the Polish word [haslo](#) (password). Initial T-Pot telemetry indicated the IP was in the Seychelles, operated via proxy chaining, and used an automated [libssh_0.12.0](#) client string. However, cross-referencing this IP with open-source intelligence ([Shodan](#)) completely deconstructs the attacker's disguise.

- **The Geolocation Illusion:** While threat intelligence feeds flagged the IP as belonging to an ISP in the Seychelles, Shodan routing data places the physical server in Los Angeles, California. The IP is registered to "[High Family Technology Co., Limited](#)," a known Chinese offshore "bulletproof" hosting syndicate. These actors legally register shell companies in offshore jurisdictions to evade international takedowns, while physically housing unmonitored servers in US datacenters.
- **The Compromised Host Profile:** When [Shodan](#) scanned this IP on May 8th (three days before my observation), it revealed a highly suspicious infrastructure profile:
 - **Ancient SSH Server:** The host was running [OpenSSH 7.4](#) (released in 2016). This extreme software age indicates a neglected or inherently vulnerable server that was likely the initial entry point for the botnet operators.
 - **C2 Web Interface:** An Nginx web server was discovered running on [port 8888](#), returning a generic 404 error and setting anomalous tracking cookies. [Port 8888](#) is heavily favored by threat actors for hosting lightweight botnet Command & Control (C2) admin panels or malware-dropping web interfaces, hidden away from standard port 80/4443 scans.



- **The Attack Lifecycle Synthesis:** By combining T-Pot session data with **Shodan** infrastructure data, we can accurately map the attack lifecycle of this specific node:
 1. *Initial Compromise:* The server was compromised, likely due to its outdated *OpenSSH 7.4* installation.
 2. *Weaponization:* The attackers deployed a custom C2 web panel (Port 8888) and uploaded a custom brute-forcing script compiled with the *libssh* library.
 3. *Execution:* On May 11th, the C2 server dispatched its *libssh* script to probe our honeypot. The script utilized a localized dictionary (containing Polish terms like *haslo* and Eastern European terms like *testik*), pointing to the human author of the botnet malware.
 4. *Obfuscation:* The server leveraged its offshore shell-company registration to feed false Seychelles GeoIP data to honeypots and SIEM systems, attempting to mask its true Los Angeles location.

Analytical Conclusion: This IP was not a simple proxy; it was a fully operational botnet node. The linguistic fingerprints in the brute-force dictionary provide a rare glimpse past the automated infrastructure, revealing an Eastern European threat actor utilizing Chinese offshore hosting infrastructure to wage automated campaigns against global targets.

2.3 The "Operator" Nodes (The Payload Delivery)

In stark contrast to the Checkers, two IPs — *42.200.66.164* (Hong Kong) and *1.214.117.218* (South Korea)—executed heavy post-exploitation payloads immediately upon logging in. These are the "Operators."



Crucially, Cowrie session tracking shows sessions 625E363E2782 (Hong Kong) and 167DB6FC9330 (South Korea) executed the *exact same* payload: injecting an SSH key for the user `mdrfckr`. This shared, unique payload proves that while the Checkers and Operators use different IP addresses, they are all limbs of the exact same botnet organism, receiving scripted instructions from a centralized server.

2.4 The Outlier: Credential Stuffing

One login from Vietnam (27.79.3.146) utilized `admin:0l0ctyQh243063uD`. This 16-character random string does not exist in any standard dictionary. This represents a completely different threat methodology—Credential Stuffing—where an attacker is testing a database of passwords leaked from an unrelated corporate breach, hoping users reused their passwords across different services. Its presence in this dataset shows how multiple threat groups simultaneously probe new internet-facing assets using entirely different philosophies.

2.5 Attack Flow Diagram

The following diagram illustrates the Division of Labor utilized by the primary SSH botnet, mapping the flow from the C2 server through the compromised proxy/checker nodes, to the payload delivery operators.

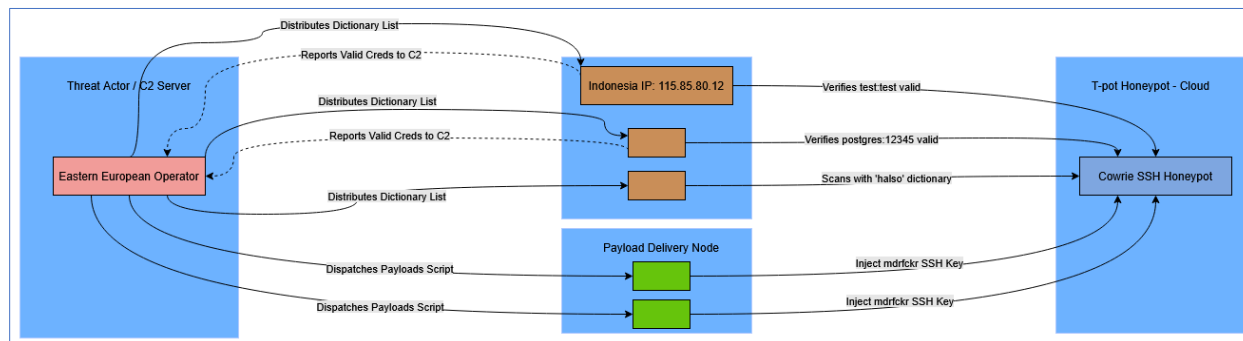


Figure 2 – This diagram summarizes how the attacks happened and where did they originally come from



3. Micro-Analysis: The mdrfckr Payload

By sequencing the commands typed by the Hong Kong Operator (42.200.66.164) second-by-second, we can reverse-engineer the attacker's automated script and understand their ultimate goal.



Figure 3 – From T-pot Dashboard: An overview of the word list used, ports that were probed and the countries that the attacks originated from.

Phase 1: Defensive Evasion

```
cd ~; chattr -ia .ssh; lockr -ia .ssh
```

- MITRE ATT&CK T1562.001 - Impair Defenses: Disable or Modify Tools
- MITRE ATT&CK T1059.004 - Command and Scripting Interpreter: Unix Shell

The script immediately attempts to remove Linux "immutable" file attributes from the `.ssh` directory. Interestingly, `lockr` is not a standard Linux command (it is likely a typo for `chattr -i` or a custom binary). This proves the script was written by a human and is being executed blindly by the botnet, highlighting the rigid, unthinking nature of automated malware.



Phase 2: Resource Profiling (The "Why")

The botnet then ran a rapid series of hardware queries:

```
cat /proc/cpuinfo | grep name | wc -l    (Count CPU cores)
free -m | grep Mem | awk '{print $2...}' (Check RAM)
df -h | head -n 2 | awk...                (Check Disk Space)
top                                       (Process Discovery)
```

- **MITRE ATT&CK T1082** - System Information Discovery
- **MITRE ATT&CK T1083** - File and Directory Discovery
- **MITRE ATT&CK T1057** - Process Discovery

Analytical Conclusion: This machine is not being prepped for ransomware (which doesn't care about specs) or data exfiltration. The attacker is calculating the computational power of the machine. This is the textbook fingerprint of Cryptomining botnet recruitment or DDoS-for-hire provisioning. The attacker is deciding if the server is "worth" infecting.

Phase 3: Hostile Takeover

```
echo -e "testsniD1EKJjW1pc6n..." | passwd | bash
```

- **MITRE ATT&CK T1098** - Valid Accounts: Manipulation

The script changes the user's password. This is a brutal tactic in the botnet economy: by changing the password, the Operator locks out the system's actual owner, and more importantly, locks out competing botnets who might try to use the same initially compromised [tests:tests](#) credential later.



Phase 4: Persistence

```
rm -rf .ssh && mkdir .ssh && echo "ssh-rsa [KEY]
mdrfckr">>.ssh/authorized_keys && chmod -R go= ~/.ssh
```

- **MITRE ATT&CK T1098.004** - Valid Accounts: SSH Key
- **MITRE ATT&CK T1222.002** - File and Directory Permissions Modification: Linux and Mac Permissions

Finally, the attacker wipes the existing SSH keys, injects their own master key, and locks down the directory permissions. Even if the real admin changes the password back, the attacker retains undetectable, passwordless access.

4. The Parallel Universe: Dionaea Service Scanning

While Cowrie watched the SSH economy, the Dionaea honeypot recorded 43 connections targeting a completely different set of vulnerabilities. This data reveals that a cloud server is not hit by one campaign but rather scanned by dozens of specialized campaigns simultaneously.

- **MITRE ATT&CK T1595.02** - Active Scanning: Word List Scanning

The Database Frenzy:

The most aggressive activity was against MongoDB ([Port 27017](#)). An Akamai/Linode IP ([173.255.226.181](#)) slammed the MongoDB port 14 times in 21 seconds. An AWS IP ([18.218.118.203](#)) joined shortly after. This is a distinct, separate botnet specifically looking for unauthenticated MongoDB databases to delete and demand ransom.



The Echoes of EternalBlue:

Two IPs— ([103.80.240.18](#)) Indonesia and ([60.190.206.118](#)) China—probed ([Port 445](#)) (SMB) multiple times. Despite being years past the WannaCry era, automated scanners looking for exposed SMB services remain a constant, humming background frequency on the internet.

Targeted Database Probing:

A Ukrainian IP ([91.232.29.206](#)) probed Microsoft SQL Server ([Port 1433](#)) using the default username [sa](#). This is a highly targeted probe, likely looking for misconfigured enterprise databases rather than executing a blind internet-wide scan.

Legitimate Noise:

Finally, the data captured ([167.94.146.52](#)) Censys and ([135.237.126.250](#)) Microsoft. T-Pot correctly identified Censys as a mass scanner. These represent the "good guys"—academic researchers and Microsoft telemetry mapping the internet. Recognizing and filtering these out is a vital part of threat analysis so defenders don't waste resources investigating legitimate indexing.



5. Conclusion & Intelligence Takeaways

This four-hour snapshot serves as a microcosm of the modern internet threat landscape. A new server is not "hacked" in a singular event; it is processed by an industrial complex.

We observed a highly efficient division of labor within an SSH botnet: compromised machines in Indonesia verifying credentials, which triggered Operators in Hong Kong and Korea to deploy cryptomining payloads. We saw evidence of the human element—the Polish word "*haslo*" slipping into a dictionary list, and a typo ("*lockr*") immortalized in an automated script. Also, we saw entirely separate economies—MongoDB ransom scanners and SMB worm probes—operating concurrently.

Defenders must assume that standard SSH credential dictionaries are entirely compromised by automated checker nodes. The primary defense mechanism must be the elimination of password-based SSH access in favor of cryptographic key-pairs, combined with strict egress filtering to prevent compromised hosts from communicating with C2 infrastructure over non-standard ports.



6. Indicators of Compromise (IOCs)

The following indicators were extracted from T-Pot telemetry (Cowrie, Dionaea, Suricata) and cross-referenced with OSINT ([Shodan](#)).

6.1 Network IOCs (Malicious Infrastructure)

Post-Exploitation Operators (High Fidelity)

Indicator	Country	ASN / ISP	Target	Context
42.200.66.164	Hong Kong	AS4760 (HKT Limited)	SSH (22)	Executed mdrfckr SSH key injection & resource profiling.
1.214.117.218	South Korea	AS3786 (LG DACOM)	SSH (22)	Executed mdrfckr SSH key injection.

Botnet C2 / Proxy Nodes

Indicator	Country	ASN / ISP	Target	Context
156.238.224.50	US (LA) / Seychelles	AS8796 (High Family Tech)	SSH (22)	Bulletproof host C2. Ran libssh with Polish dictionary.
115.85.80.12	Indonesia	AS23953 (PT ARTHA)	SSH (22)	Checker node verifying tests:tests.
43.160.200.19	Singapore	AS132203 (Tencent)	SSH (22)	Checker node verifying stuser:stuser.
27.79.3.146	Vietnam	AS7552 (Viettel)	SSH (22)	Credential stuffing (Complex string 0l0ctyQh...).



Database & Service Scanners (Medium Fidelity)

Indicator	Country	ASN / ISP	Target	Context
173.255.226.181	US (NJ)	AS63949 (Akamai/Linode)	MongoDB (27017)	Rapid automated DB ransom scanning.
18.218.118.203	US (OH)	AS16509 (Amazon AWS)	MongoDB (27017)	Rapid automated DB ransom scanning.
103.80.240.18	Indonesia	AS136054 (PT.COMTELINDO)	SMB (445)	Repeated vulnerability probing.
60.190.206.118	China	AS4134 (Chinanet)	SMB (445)	Repeated vulnerability probing.
91.232.29.206	Ukraine	AS3236 (Server.ua)	MSSQL (1433)	Default sa credential probing.

Attacker AS/N - Top 10			Attacker Source IP - Top 10	
AS	ASN	Count	Source IP	Count
23470	ReliableSite.Net LLC	822	104.243.32.126	573
14061	DigitalOcean, LLC	463	85.11.167.11	373
213438	ColocaTel Inc.	373	42.200.66.164	357
4760	HKT Limited	357	115.85.80.12	288
23953	PT ARTHA TELEKOMII	288	185.150.191.236	247
63949	Akamai Connected Clr	273	156.238.224.50	219
132203	Tencent Building, Keji	232	43.160.200.19	219
8796	FASTNET DATA INC	219	1.214.117.218	151
3786	LG DACOM Corporatic	163	204.76.203.231	113
213412	ONYPHE SAS	154	177.92.52.100	67
Rows per page: 10			Rows per page: 10	

Figure 4 – From T-pot Dashboard



6.2 Cryptographic IOCs

Malicious SSH Authorized Key (CRITICAL): If the following public key is found in `~/.SSH/AUTHORIZED_KEYS` on a Linux asset, the host is fully compromised by the [mdrfckr](#) botnet operator.

```
ssh-rsa
AAAAB3NzaC1yc2EAAAABJQAAAQEArdp4cun2lhr4KUhBGE7VvAcwdli2a8dbnrTOrbMz1+5O73f
cBOx8NVbUTObUanUV9tJ2/9p7+vD0EpZ3Tz/+0kX34uAx1RV/75GVomNx+9EuWOnvNoaJe0QX
xzilg9eLBHpgLMuakb5+BgTFB+rKJAw9u9FSTDengvS8hX1kNFS4Mjux0hJOK8rvcEmPecjdySYMb
66nylAKGwCEE6WEQHmd1mUPgHwGQ0hWCwsQk13yCGPK5w6hYp5zYkFnlC8hGmd4Ww+u
97k6pfTGTUbjk14ujvcD9iUKQTTWYYjllu5PmUux5bsZOR4WFwdle6+i6rBLAsPKgAySVKPRK+oRw
== mdrfckr
```

HASH Fingerprint (Botnet Client): Used to track the specific [libssh](#) brute-force script across different IP addresses.

- [af8223ac9914f509afdadfaf5f7ee94e](#)

SSH Server Fingerprint (Compromised C2 Host) The host key of the bulletproof C2 server located in Los Angeles ([OpenSSH 7.4](#)).

- [09:ea:45:09:c1:58:ec:43:82:a3:8b:98:05:cb:55:15](#)

6.3 Observed Authentication Material (Contextual)

While not traditional IOCs, the following credentials were explicitly targeted by the botnet's dictionary and stuffing lists. Security teams should ensure these username/password combinations do not exist in their environments.

- [tests:tests](#)
- [postgres:123456](#)
- [stuser:stuser](#)
- [ubuntu:ubuntu](#)
- [test:haslo](#)
- [admin:0l0ctyQh243063uD](#) (Leaked credential)



6.4 Exclusions / Whitelisted IOCs (Do Not Block)

The following IPs were observed during the telemetry window but have been verified as benign internet background noise, academic research, or vendor telemetry. They should be excluded from automated blocking rules to prevent service disruption.

Indicator	Organization	Reason for Exclusion
167.94.146.52	Censys, Inc.	Legitimate internet mapping and research scanner.
135.237.126.250	Microsoft Corporation	Standard Microsoft telemetry scanning for exposed services.
184.105.139.70	Hurricane Electric	Legitimate BGP and internet backbone routing research.